ISO/IEC 20000.
Guía completa de aplicación para la gestión de los servicios de tecnologías de la información

ISO/IEC 20000. Guía completa de aplicación para la gestión de los servicios de tecnologías de la información

AENOR ediciones

Título: *ISO/IEC 20000. Guía completa de aplicación para la gestión de los servicios de tecnologías de la información*

Telefónica, S.A.

Coordinador: Luis Morán Abad

© AENOR (Asociación Española de Normalización y Certificación), 2009

Todos los derechos reservados. Queda prohibida la reproducción total o parcial en cualquier soporte, sin la previa autorización escrita de AENOR.

© Crown copyright 2007 All rights reserved. Material is reproduced with the permission of the Office of Government Commerce under delegated authority from the Controller of HMSO.



ITIL® is a Registered Trade Mark of the Office of Government Commerce in the United Kingdom and other countries.

The Swirl logo™ is a Trade Mark of the Office of Government Commerce.

The OGC logo® is Registered Trade Mark of the Office of Government Commerce in the United Kingdom.

PRINCE® is a Registered Trade Mark of the Office of Government Commerce in the United Kingdom and other countries.

IT Infrastructure Library® is Registered Trade Mark of the Office of Government Commerce in the United Kingdom and other countries.

M_o_R® is Registered Trade Mark of the Office of Government Commerce in the United Kingdom and other countries.

ISBN: 978-84-8143-662-4
Depósito Legal: M-47292-2009
Impreso en España - *Printed in Spain*

Edita: AENOR
Maqueta y diseño de cubierta: AENOR
Imprime: Xxxxxx

Nota: AENOR no se hace responsable de las opiniones expresadas por los autores en esta obra.

AENOR Asociación Española de Normalización y Certificación

Génova, 6. 28004 Madrid • Tel.: 902 102 201 • Fax: 913 103 695
comercial@aenor.es • www.aenor.es

Este libro está dedicado a todos los profesionales de tecnologías de la información y las comunicaciones que abnegadamente han aportado sus conocimientos y experiencia para la definición y difusión de las normas y las mejores prácticas que marcan el camino de evolución de este sector.

Agradecimientos

Este libro recopila las experiencias de profesionales que están fuertemente involucrados en el impulso de las normas y las buenas prácticas internacionales relativas a la gestión de las tecnologías de la información y las comunicaciones.

En la creación de esta primera edición del libro han participado:

- Dirección de la obra (Telefónica):

  Luis Morán Abad – Dirección técnica y contenido final.

  Alejandro Pérez Sánchez – Contenido intermedio.

- Autores principales (Telefónica):

  Luis Morán Abad

  Alejandro Pérez Sánchez

  Juan Trujillo Gaona

  David Bathiely Fernández

  Miguel José González-Simancas Sanz

- Colaboradores:

  Paloma García López (AENOR)

  Carlos Manuel Fernández Sánchez (AENOR)

  Eduardo Méndez Polo (Telefónica)

  Jaime Pastor Pastor (Telefónica)

Tomás Hernández López (Telefónica)

Carmen Fernández Prieto (Telefónica)

María Luisa López de Castro (Telefónica)

Julio Morilla Padial (Telefónica)

Andrés Leiva Araos (Telefónica)

Ronaldo Gonçalves Tiago (Telefónica)

Julio José Ballesteros García (Quint Group)

Luis Miguel Rosa Nieto (EXIN España)

Pablo Castro Montero

(Entre paréntesis se indica la empresa en la que trabajaban a fecha 01.01.2009.)

- El control independiente de idoneidad técnica de los contenidos está avalado por profesionales de itSMF España y de AENOR, junto con otros profesionales independientes:

  Carlos López Alonso (Hewlett-Packard) por itSMF España

  Antonio José Rodríguez (Quint Group) por itSMF España

  Ana Ramos (British Telecom) por itSMF España

  Leopoldo Martínez-Osorio del Río (INDRA) por itSMF España

  Carmen Caballero (INDRA) por itSMF España

  Manuel Fernando Juan Martínez (Banco de Santander)

  Julio González Sanz

  Boris Delgado Riss (AENOR)

Agradecer también a la dirección de Sistemas de Información de Telefónica que de forma directa ha hecho posible esta publicación:

María Fernanda Torquati (Telefónica)

José María Tavera Más (Telefónica)

Fabriciano Gangoso Alonso (Telefónica)

Isidro Abad Gosalvez (Telefónica)

Índice

Presentación 13

Introducción 15

Capítulo 1. El camino a la excelencia ya existe 21

1.1. Las Normas ISO/IEC 20000 son parte del camino a la excelencia 23

1.2. Normas, estándares, marcos de referencia y metodologías reconocidas en el ámbito de las TI 24

1.3. Entender los entornos de normalización y certificación 27

1.4. Las principales normas y buenas prácticas en TI 37

Capítulo 2. Entender las Normas ISO/IEC 20000 51

2.1. Introducción a las Normas ISO/IEC 20000 53

2.2. Objeto y campo de aplicación de ISO/IEC 20000 65

2.3. La estructura de las Normas ISO/IEC 20000 70

2.4. Relación entre ISO/IEC 20000 e ITIL 75

Capítulo 3. El Sistema de Gestión del Servicio de TI (SGSTI) 79

3.1. El sistema de gestión de tecnologías de la información 83

Capítulo 4. Planificación e implementación de la gestión del servicio 107

4.1. Cómo planificar e implementar la gestión del servicio 111

Capítulo 5. Planificación e implementación de nuevos servicios o de servicios modificados 149

5.1. El proceso de planificación e implementación de nuevos servicios o de servicios modificados 153

Capítulo 6. Procesos de provisión de servicio 191

6.1. Gestión de nivel de servicio 195

6.2. Generación de informes del servicio 237

6.3. Gestión de la continuidad y disponibilidad del servicio 279

6.4. Elaboración de presupuestos y contabilidad de los servicios de TI 331

6.5. Gestión de la capacidad 369

6.6. Gestión de la seguridad de la información 403

Capítulo 7. Procesos de relaciones 449

7.1. Generalidades 453

7.2. Gestión de las relaciones con el negocio 457

7.3. Gestión de suministradores 485

Capítulo 8. Procesos de resolución 535

8.1. Antecedentes 539

8.2. Gestión del incidente 545

8.3. Gestión del problema 589

Capítulo 9. Procesos de control 619

9.1. Gestión de la configuración 623

9.2. Gestión del cambio 661

Capítulo 10. Procesos de entrega 693

10.1. Gestión de la entrega 697

Capítulo 11. La certificación conforme a ISO/IEC 20000 de la gestión del servicio de TI 733

11.1. La primera certificación conforme a ISO/IEC 20000 737

11.2. Evidencias y registros importantes en una certificación 751

Bibliografía y referencias 763

Términos y definiciones 767

Presentación

Las tecnologías de la información son cada día más necesarias en la gestión de las empresas.

Este sector, en su evolución hacia la madurez, ha ido generando diversos conjuntos de mejores prácticas que ayudan a las organizaciones a gestionar estos entornos tecnológicos cada vez más complicados y, por otra parte, más esenciales.

Este libro nace con la intención de ayudar a todo tipo de empresas en la gestión de la actividad de sus departamentos informáticos. Profesionales de Telefónica y de AENOR han puesto su mejor empeño en explicar y aportar sus años de experiencia en este ámbito. Para ello, se ha utilizado como eje vertebrador las Normas UNE-ISO/IEC 20000, que se enriquecen con las buenas prácticas de otros marcos como ITIL®.

Los autores han desarrollado una buena guía sobre la forma de incorporar estas mejores prácticas de la industria en la gestión diaria de las tecnologías. Esta publicación ayudará a las empresas a adoptar los últimos avances en la forma de organizar las actividades que contribuyen a que el mundo tecnológico sea operativo y rentable para las organizaciones y para la sociedad.

Esperamos que todo su contenido sea de gran utilidad en la mejora de los servicios de tecnologías de la información prestados en su organización.

Telefónica

Introducción

Durante la década de los años 50, algunas predicciones futuristas imaginaron que, para el año 2000, los coches serían capaces de volar, se iría de vacaciones a Marte, y que Estados Unidos podría llegar a contar con "nada menos" que trescientos mil ordenadores. En 1947 el director de una famosa multinacional del sector predijo que en el mundo sólo habría mercado para 5 ordenadores. Estas predicciones hoy en día nos parecen ridículas, unas por lo exageradas, y otras por que se han quedado muy cortas.

Las tecnologías de la información y las comunicaciones han avanzado mucho más de lo esperado, pero después de poblar el mundo de dispositivos de silicio, con unas capacidades de proceso inimaginables, nos encontramos con un panorama desalentador:

- Equipos que se bloquean.
- Sistemas que se "caen".
- Servicios que se interrumpen.
- Atención al usuario deficiente.
- Pérdidas de tiempo y de productividad de los usuarios.
- Personal técnico desbordado por llamadas y peticiones de asistencia.
- Directores de sistemas de información que ven cómo, a pesar del esfuerzo continuo de su equipo, el roce y el malestar con el resto de la empresa no cesan.

Por ello, no es de extrañar que encontremos frecuentemente que los departamentos de las tecnologías de la información (TI) se consideren más una carga que una ayuda para el negocio.

La dinámica industria de tecnologías de la información y las comunicaciones (TIC), que es capaz de duplicar la capacidad de proceso y de almacenamiento cada año y medio, lleva desarrollando, en paralelo al avance tecnológico, metodologías de trabajo que van ofreciendo soluciones de gestión a estos retos planteados. El sector de las TIC ha ido creando distintas disciplinas para cubrir algunas de las facetas que necesita la gestión global de las TIC en la empresa. Soluciones que no siempre se han aplicado con el ahínco y el rigor necesarios.

Parece lógico que los organismos de normalización internacionales, como ISO (*International Organization for Standardization*, Organización Internacional de Normalización) e IEC (*International Electrotechnical Commission*, Comisión Electrotécnica Internacional), propicien la elaboración de normas que van consolidando las prácticas establecidas relativas a la organización del trabajo en las áreas de TI. Además, estos organismos de normalización disponen de mecanismos de trabajo asentados que garantizan una amplia participación de los agentes del sector de las TIC. Este es el caso de las Normas ISO/IEC 20000, partes 1 y 2, y sus traducciones oficiales al castellano, publicadas por AENOR como Normas UNE-ISO/IEC 20000[1] en junio de 2007. El presente libro se centra en explicar la aplicación de estas dos normas.

Las Normas ISO/IEC 20000 definen los procesos y las actividades esenciales para que las áreas de TI puedan prestar un servicio eficiente y alineado con las necesidades de la empresa u organización. Estas normas, construidas sobre la base del modelo ITIL, se centran principalmente en la ordenación de las disciplinas de soporte y provisión de servicios de TI. Son normas específicas para la gestión de los servicios que ofrecen las áreas o los proveedores de tecnologías de la información.

Las Normas ISO/IEC 20000 no son de índole técnico, ni tecnológico. En ellas se describen los principales flujos de actividades (agrupados en forma de procesos) cuyo fin es lograr una entrega efectiva y con la calidad requerida de los servicios a los clientes y usuarios. Además, definen un sistema reconocido y probado de gestión que permite a los proveedores de TI (ya sean áreas internas u organizaciones externas) planificar, gestionar, entregar, monitorizar, informar, revisar y mejorar sus servicios.

Objeto del libro

Este libro se centra en explicar y facilitar la comprensión de las Normas ISO/IEC 20000 con un enfoque práctico, para que su implantación resulte efectiva en

[1] Para facilitar la lectura, en el resto del libro se ha optado por utilizar el mismo término "ISO/IEC 20000" para referirse a estas normas, tanto para la serie UNE, como para la serie ISO/IEC.

cualquier tipo de organización que provea servicios de tecnología, tanto internamente a su organización como externamente al mercado, tanto en grandes organizaciones como en pequeñas o medianas empresas.

Este libro va dirigido a todos los profesionales del ámbito de las tecnologías de la información y las comunicaciones que estén involucrados en la provisión de servicios. Resultará imprescindible tanto a los responsables de su gestión, como a cualquier otro profesional de TI: dirección, gestores, responsables de procesos, consultores, técnicos, personal de soporte, etc.

Al avanzar en este libro, el lector constatará que la industria ya ha normalizado gran parte del conjunto de actividades necesarias para que los servicios proporcionados por las TI sean fiables y eficientes. Cubren desde las actividades del día a día inmediato, como es la atención a los incidentes y peticiones, hasta la definición de una estrategia que permita continuar prestando los servicios en caso de catástrofe, todo ello, sin olvidar conceptos como la planificación o la mejora continua.

Persiguiendo este fin último de utilidad, los contenidos de cada apartado, además de incluir íntegramente la norma, se han enriquecido con otras buenas prácticas ITIL y con la amplia experiencia profesional de los autores.

Por tanto, este libro pretende ser una guía completa de aplicación, una ayuda y una razonable interpretación de estas normas. No pretende sentar "jurisprudencia" al respecto. Los autores dan por hecho que puede haber otras formas de aplicar o interpretar las directrices de las normas, ya que las particularidades de cada negocio y organización tienen gran influencia.

Estructura del libro

Se ha puesto énfasis en que los contenidos ayuden a la transformación real y perceptible de la gestión de las TI en toda empresa que se inicie en el camino de la aplicación de ISO/IEC 20000.

El capítulo 1 "El camino a la excelencia ya existe", introduce al lector en las nuevas tendencias de gestión de las TI, como son: la orientación a procesos, la calidad, las normas y las mejores prácticas. La intención del capítulo es presentar el amplio, y cada vez más complejo, entorno normativo y de mejores prácticas. Se conocerá quiénes son los principales actores en estos ámbitos y se tendrá una primera aproximación de cómo se posiciona cada norma o iniciativa. Este capítulo es un paso previo, que proporciona una visión general de todo este escenario internacional, antes de zambullirse en las especificidades de las Normas ISO/IEC 20000.

El capítulo 2 "Entender las Normas ISO/IEC 20000" las posiciona en el ámbito global de las TIC, para pasar después a explicar su alcance, su estructura, sus coincidencias y las principales diferencias frente a ITIL. Este capítulo resulta esencial para entender adecuadamente los siguientes.

Para facilitar la comprensión, el núcleo central del libro, desde el capítulo 3 al 10, se organiza siguiendo una estructura de capítulos y numeración de apartados paralela a las normas de referencia. En la figura I.1 se muestra este paralelismo intencionado.

El capítulo 3 "El Sistema de Gestión del servicio de TI (SGSTI)", explica este concepto que suele resultar nuevo para los profesionales de las TIC no acostumbrados a los sistemas de gestión definidos en la normativa de calidad ISO. Explica con detalle la creación de un sistema de gestión aplicado a la provisión y soporte del servicio de tecnologías de la información. Este sistema de gestión constituye en sí mismo el diseño de las nuevas formas de hacer que transformarán el servicio de TI. Su utilización ofrece un valor añadido y permitirá alcanzar una posición diferencial a las organizaciones que lo implementen.

En el capítulo 4 "Planificación e implementación de la gestión del servicio", se trata la implantación de las Normas ISO/IEC 20000. Explica la forma de organizar y llevar a cabo esta transformación que suponen las nuevas formas de hacer, acordes con estas normas y definidas en el sistema de gestión. Se explican los aspectos que hay que tener en cuenta previos a la implantación, para entrar posteriormente en el ciclo de mejora continua. Se sigue el enfoque a las cuatro etapas del ciclo de mejora continua (PDCA, de Deming o de Shewhart), que también se explica en este capítulo.

Los capítulos del 5 al 10 se corresponden con los principales procesos identificados en la gestión del servicio relativos a: creación, provisión, relaciones, resolución, control y entrega del servicio.

En el libro, también se ha considerado que las empresas, además de mejorar sus servicios de TI, quieren obtener una certificación que les acredite ante su Dirección o ante sus clientes de la conformidad de su gestión frente a los requisitos de estas normas de referencia. A este respecto, el capítulo 11 es una guía que explica el proceso habitual para obtenerla.

El libro se ha preparado para que se pueda leer en tres recorridos diferentes:

- **Recorrido 1: lectura rápida.** Paso rápido por los conceptos del libro, sin profundizar en los procesos. Este recorrido pasa por la lectura de los capítulos 1, 2 y 3 en detalle, pues contienen conceptos y posicionamientos que nadie debería descartar. A partir de este punto, el resto de los capítulos y procesos tienen su introducción y gráficos que resumen los principales conceptos que todo involucrado en las TI debería conocer.

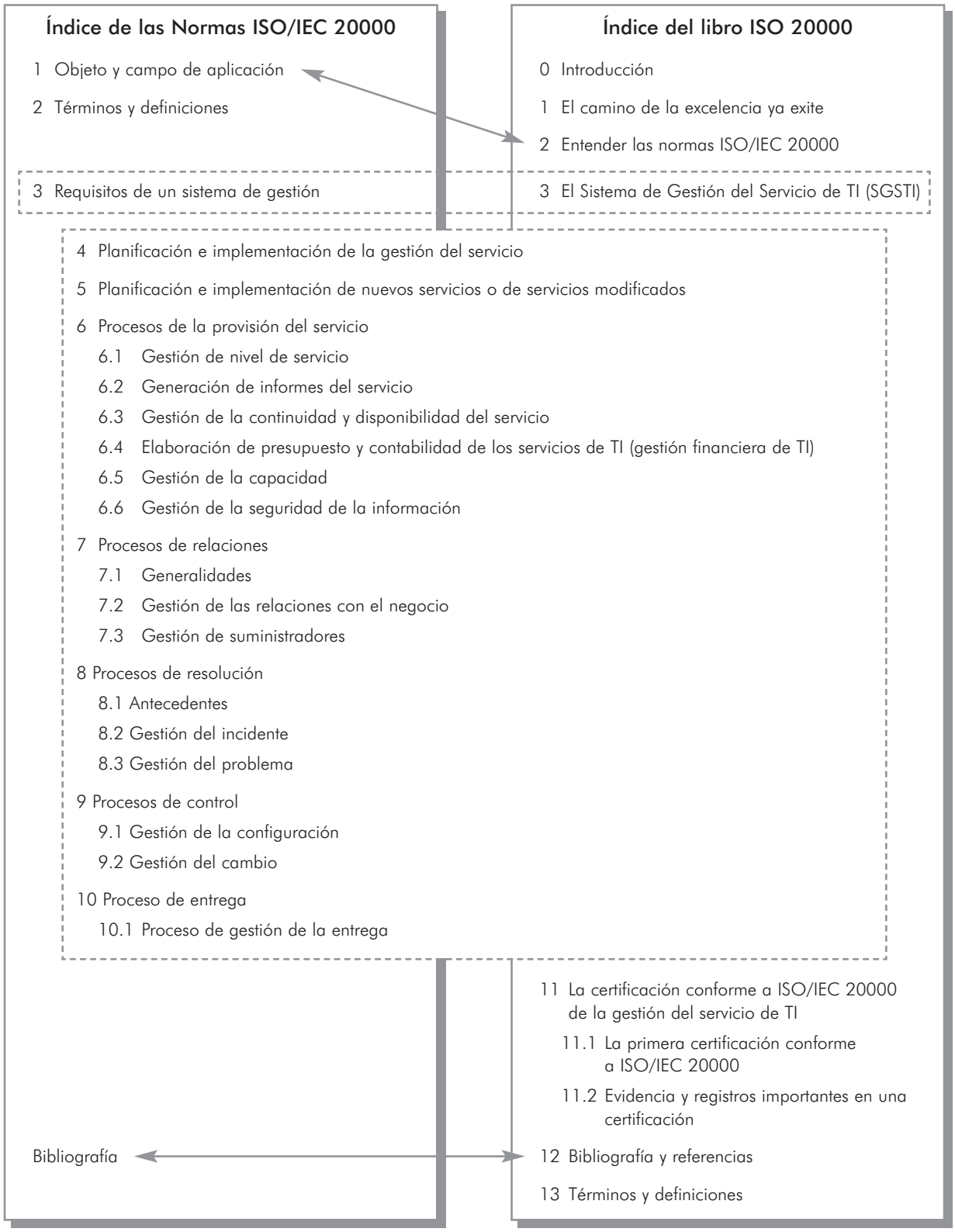


Figura I.1. **La estructura del libro transcurre paralela a las Normas ISO/IEC 20000**

- **Recorrido 2: lectura secuencial y a fondo**. De principio a fin, que es la recomendada por los autores.
- **Recorrido 3: manual de consulta**. La estructura del libro con temática independiente permite utilizarlo también como manual de consulta, accediendo directamente a cada proceso.

1

Capítulo 1

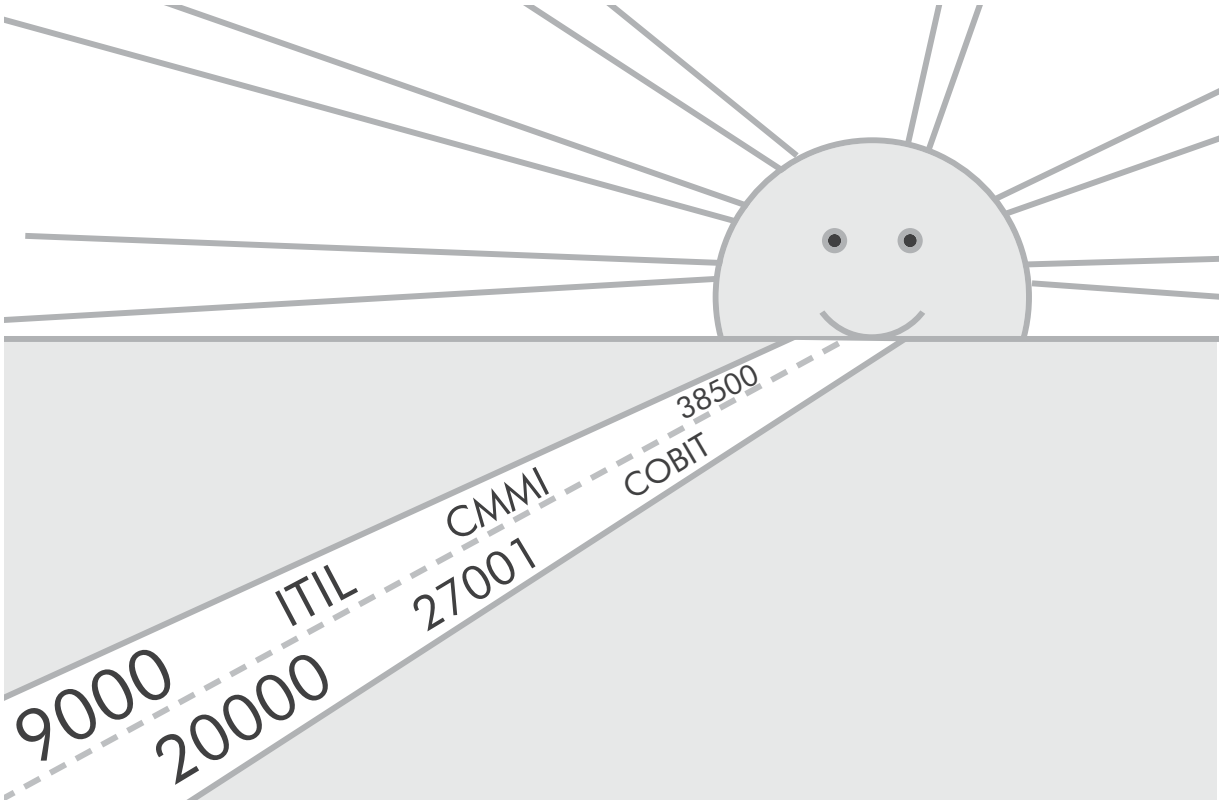
El camino a la excelencia ya existe

1.1. Las Normas ISO/IEC 20000 son parte del camino a la excelencia

1.2. Normas, estándares, marcos de referencia y metodologías reconocidas en el ámbito de las TI

1.3. Entender los entornos de normalización y certificación

1.4. Las principales normas y buenas prácticas en TI



1.1. Las Normas ISO/IEC 20000 son parte del camino a la excelencia

Comparando la gestión habitual de las tecnologías de la información con otras áreas de la empresa, podremos encontrar que, en las más avanzadas, existen modelos de gestión firmemente establecidos que las hacen parecerse al modelo de una orquesta sinfónica en la que, si bien cada músico es un excelente especialista en su instrumento, es en la interpretación del concierto cuando la orquesta demuestra su auténtico valor actuando como un todo.

En cambio, las áreas que gestionan sistemas tecnológicos han puesto tradicionalmente el foco en el conocimiento y dominio de la tecnología. Es esencial y obvio que se necesitan buenos técnicos para el diseño, la construcción y el mantenimiento del *hardware* y del *software*. Sin embargo, la situación actual refleja que el control de la técnica, aunque totalmente imprescindible, no es suficiente para satisfacer todo lo que la empresa demanda de las áreas de TI. Queda una importante asignatura pendiente que, por más que se invierta en tecnología y en técnicos, no se consigue resolver: actuar perfectamente engranados, todos juntos y bien coordinados para conseguir un fin común: ser cada vez más eficientes en costes y capaces de evolucionar con la agilidad típica del "ecosistema" Internet (objeto de deseo de todos los negocios para sus áreas de TI).

Los responsables de los departamentos de TI deben responder a importantes desafíos: la eficiencia en costes, la calidad, el cumplimiento de plazos, la agilidad y la satisfacción de los clientes y usuarios están entre ellos. La gestión de las TI debe evolucionar desde los modelos artesanales hacia formas de hacer más industrializadas. Implementar formas de trabajo repetibles, mejorando la calidad de lo construido, la fiabilidad de los servicios o aumentando la capacidad de "producción" de la organización, todo ello, dentro de un nuevo entorno más fluido en las relaciones y que genere menos estrés en las personas. En esta evolución, las buenas prácticas sectoriales recogidas en las Normas ISO/IEC 20000, en los libros ITIL, en otras normas y marcos de referencia, marcan el camino a recorrer para alcanzar la excelencia en la gestión de las TI.

Del mismo modo que un abogado debe conocer las leyes para ejercer su profesión, o un arquitecto la legislación y reglamentación sobre urbanismo y edificación; la dirección y los profesionales de los departamentos de TI deben conocer con detalle el conjunto de buenas prácticas, normas o estándares que se están consolidando en su propio sector. La actividad de los directivos y profesionales de las TI, debe pasar por conocer con detalle la normativa y marcos de las mejores prácticas aceptados por el mercado, para aplicarlas posteriormente en su organización. Este es un buen camino para la mejora de las actividades.

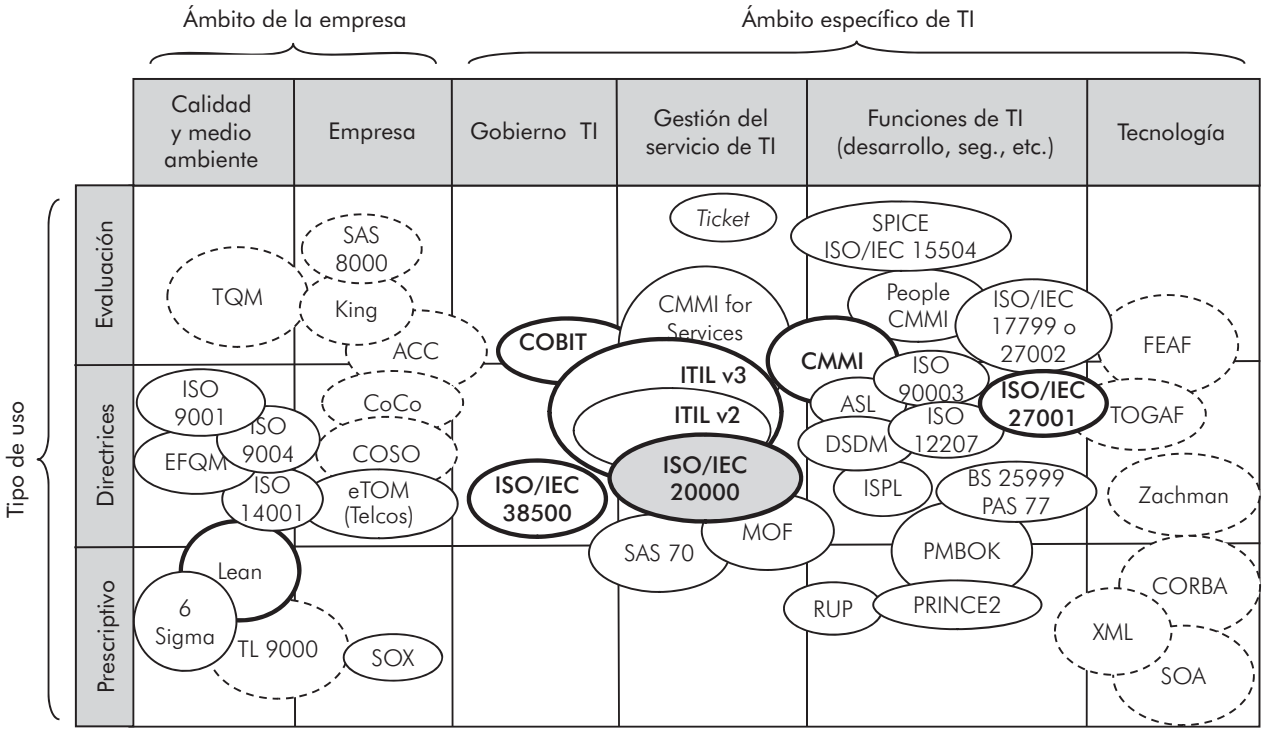
1.2. Normas, estándares, marcos de referencia y metodologías reconocidas en el ámbito de las TI

El mundo de la ciencia está empeñado en la búsqueda de una ley universal que sea válida tanto para el mundo del átomo como para las grandes galaxias. De manera análoga, en el ámbito de las TI todavía no se ha conseguido definir un modelo formal universal de toda su actividad que contemple desde la más detallada tarea técnica, hasta la definición al más alto nivel de la estrategia alineada con el negocio.

El interés por mejorar las actividades de las TI ha hecho que se hayan ido desarrollando varios marcos o modelos que cubren las principales parcelas de la gestión y del conocimiento. A veces son complementarios entre sí, en otros aspectos se solapan y, con frecuencia, presentan enfoques distintos sin ofrecer una integración clara con otros modelos o aproximaciones. A pesar de ello, es indudable la utilidad de trabajar con éstos modelos de referencia ya definidos y los beneficios que aportan a las organizaciones que los utilizan como base para avanzar.

Una buena representación que permite realizar una primera aproximación a este mundo en ebullición de normas, modelos y marcos de referencia, es la realizada por la consultora Gartner Group, presentada en la figura 1.1. En ella, se posicionan las normas en función de dos conceptos: el ámbito de aplicación y el tipo de uso de la normativa. El ámbito de aplicación de las normas ocupa las columnas de la tabla y se divide en dos alcances: el general de la empresa y las disciplinas específicas de TI (gobierno de TI, gestión del servicio de TI, funciones de TI y tecnología). El tipo de uso de la normativa se representa en tres filas: normativa con foco en la evaluación de la actividad, directrices y mejores prácticas, y la normativa de carácter más prescriptivo. La tabla original de Gartner se ha actualizado con la contribución de los autores, incorporando nuevas normas y marcos de referencia, como: ITIL v3, CMMI for Services, ISO/IEC15504, ISO/IEC 38500, ISO 9004, ISO14001, ISO 90003, ISO/IEC 27001, PRINCE2, ISPL, ASL y DSDM). La dinámica de este sector hará que en breve aparezcan nuevas normas y estándares para incorporar a éste gráfico.

Entre estos modelos o recomendaciones destacan las Normas **ISO/IEC 20000**, que compiten por un reconocimiento en este campo. El hecho de llegar con el respaldo de los organismos de normalización internacionales, es un claro empuje para que se asiente como un referente en la sociedad. Como además, se han publicado también como norma nacional en muchos países, cumplen todo lo necesario para que los gobiernos puedan incluirlas en sus legislaciones o regulaciones (pudiendo llegar a convertirse en obligatorias).



Fuente: Gartner y e.p.

Figura 1.1. **Mapa de las diferentes normas y marcos de referencia relacionados con las TI**

El veterano marco **ITIL** destaca como el gran compendio de referencia, que aspira a convertirse en ese modelo universal que estructura y organiza toda la actividad de las TI. Si bien la versión 2, publicada en el año 2000, ha tenido una aceptación excepcional, hay que esperar a ver cómo el sector va adoptando la nueva versión 3, publicada en el año 2007, y que presenta una visión más amplia y coherente de la gestión de las TI, agrupada en torno al ciclo de vida del servicio.

El marco para el desarrollo de *software* CMMI (*Capability Maturity Model Integration*) aparece como el modelo más aceptado para la medición de la madurez de los procesos de gestión en la construcción de aplicaciones. Para complicar más el panorama, en su última versión se crea un nuevo modelo **CMMI *for Services***, que se superpone en gran medida con el ámbito central de ITIL; y por tanto, también con las Normas ISO/IEC 20000. Además, para los procesos y medición de la madurez del desarrollo, también la normativa internacional inició desde 1993 su andadura. ISO e IEC han desarrollado un modelo para la evaluación de los procesos de desarrollo de *software* bajo la iniciativa SPICE que ha desembocado en la publicación de la serie ISO/IEC 15504. En paralelo, han ido evolucionando otro conjunto de normas relativas a la ingeniería del *software* (ISO/IEC 15288, ISO/IEC 12207, ISO/IEC 25001, ISO/IEC 25030, ISO/IEC 16085, etc.).

La gestión de la seguridad de los sistemas de información ha sido una de las áreas más difundidas en el entorno normativo de las TI, con las normas **UNE-ISO/IEC 27001** (sistema de gestión de seguridad) y **UNE-ISO/IEC 17799** (un código de buenas prácticas para la gestión de la seguridad de la información), que se ha renumerado como UNE-ISO/IEC 27002. Recientemente han aparecido unas normas británicas sobre la gestión de la continuidad de negocio, denominadas **BS 25999.**

En el ámbito de la auditoría, medición y gobierno de TI el modelo **COBIT** (*Control Objectives for Information and Related Technology*) está reconocido como una excelente referencia. En relación al gobierno de las TI, la normativa internacional de ISO ha tomado posiciones con la nueva Norma **ISO/IEC 38500** *Corporate Governance of Information Technology* (también denominada en sus etapas de borrador como 29382), inspirada en la Norma australiana AS 8015. Como un hijo menor del modelo COBIT, para la medición del valor que aportan las TI al negocio, se ha definido un nuevo "sub-marco" denominado ValIT.

En relación a la gestión de proyectos de desarrollo de *software*, el marco líder es **PMBOK** (*Project Management Body of Knowledge*), una metodología reconocida por el organismo norteamericano de normalización ANSI. También hay que tener en cuenta el modelo **PRINCE2** (*Projects In Controlled Environments*) que, realizado por los impulsores de ITIL, es más sencillo que el anterior, y resulta de utilidad para proyectos de mejora y de implantación de ITIL o de ISO/IEC 20000.

Otros modelos que se complementan o solapan con los anteriores, aunque con poca aceptación en el sector de las TI son: en el ámbito de la gestión de proveedores ISPL (*Information Services Procurement Library*), para disponer de un mapa completo en la construcción de aplicaciones: ASL (*Application Services Library*) o DSDM (*Dynamic Systems Development Method*).

Por su importancia y universalidad, también hay que tener en cuenta la serie de normas internacionales ISO 9000, familia de normas y directrices que contienen los requisitos para la gestión de la calidad general de una organización. Dentro de esta serie destaca la Norma **UNE-EN ISO 9001**, que contiene los requisitos del sistema de gestión de la calidad, también esencial para la implantación de las Normas ISO/IEC 20000. La Norma **UNE-EN ISO 9004** contiene recomendaciones prácticas para aquellas empresas que quieran ir más allá de los requisitos mínimos establecidos en UNE-EN ISO 9001.

En el ámbito de la calidad aplicada al desarrollo de *software*, también hay que considerar la Norma **UNE-ISO/IEC 9003** que versa sobre las directrices para la aplicación de la Norma UNE-EN ISO 9001 al desarrollo de *software*. Por otra parte, la Norma **ISO/IEC 12207** proporciona un marco para los procesos, actividades y tareas relacionadas con el ciclo de vida del *software*.

Por otra parte, los temas medioambientales también tienen su impacto en la gestión de TI. Deben tenerse en cuenta: la legislación nacional, local y la normativa sobre retirada y gestión del equipamiento y residuos informáticos; la serie de Normas **ISO-EN 14000** relativa a la gestión medioambiental; en España existe también la Norma **UNE 150002** *Sistemas de gestión medioambiental. Guía para la aplicación de la norma UNE-EN ISO 14001:1996 en las empresas de servicios* y la guía para la aplicación de los sistemas de gestión medioambiental a las relaciones con suministradores y clientes, denominada **UNE 150004 EX**; o el Código de Conducta para la Eficiencia Energética en Centros de Datos publicado por la Unión Europea.

Tanta abundancia de información y recomendaciones resulta confusa para las organizaciones que sólo desean soluciones prácticas y directas para mejorar su gestión de las TI.

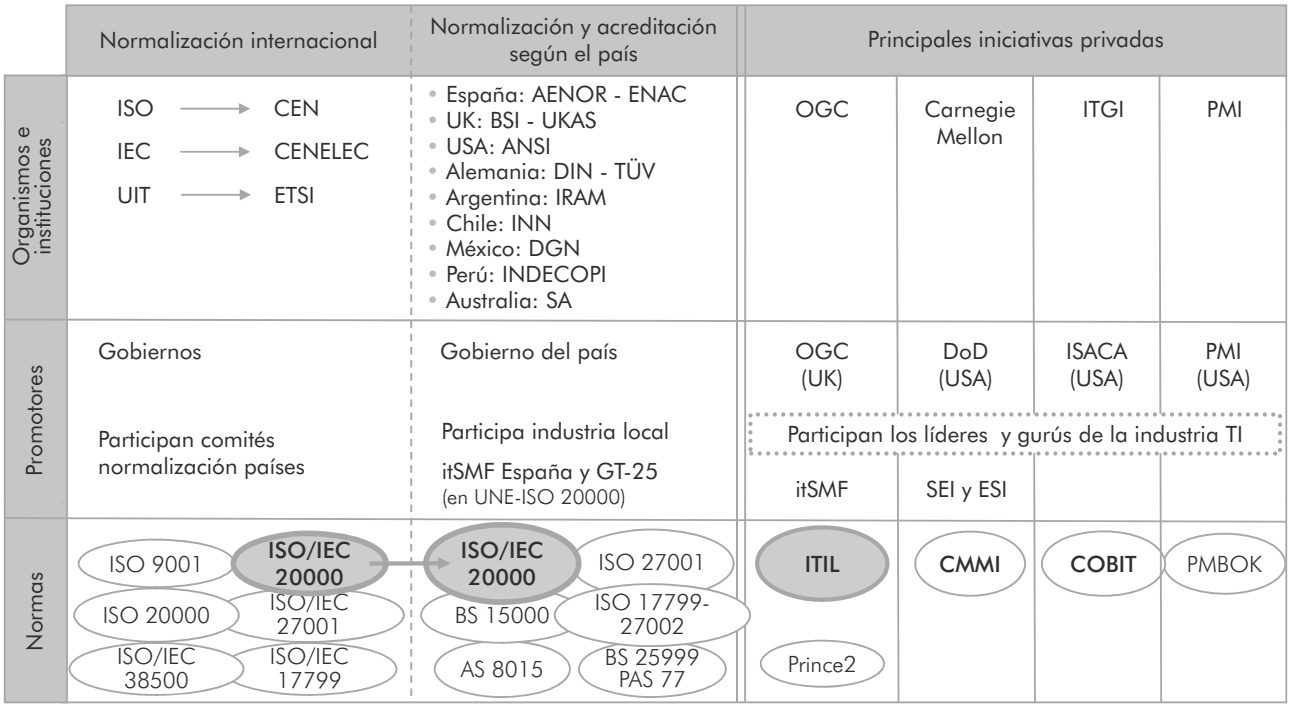
De todo el mapa anterior, se recomienda centrarse inicialmente en las normas y marcos de mayor relevancia y más aceptados para la mejora de TI, como son:

- ISO/IEC 20000 partes 1 y 2, e ITIL (en sus versiones 2 y 3) para mejorar la gestión de los servicios de TI.
- COBIT para la auditoría y la medición de las TI.
- ISO/IEC 27001 para la gestión de la seguridad de la información.
- ISO/IEC 15504 y CMMI for Development para la gestión del desarrollo de *software*.
- ISO/IEC 38500 y COBIT como referencias para el gobierno de las tecnologías de la información.

1.3. Entender los entornos de normalización y certificación

Tiene gran interés conocer "quién es quién" en el ámbito de la normalización y la definición de las buenas prácticas relacionadas con la provisión de servicios de TI. Concurren en este espacio: organizaciones internacionales y europeas de carácter multisectorial que producen normas (como ISO, IEC, CEN, CENELEC, ETSI, UIT), organismos de normalización nacionales (AENOR en España, BSI en UK, etc.), administraciones públicas e instituciones gubernamentales (como OGC en UK, DoD en los EEUU), organizaciones privadas (itSMF, ITGI), universidades (Carnegie Mellon), junto a otros organismos del mundo de la certificación y acreditación de empresas. La figura 1.2 presenta en forma de tabla los principales actores. En las columnas se muestran las instituciones generadoras de normativas y

marcos de mejores prácticas (organismos de normalización internacional, organismos de normalización en cada país y las principales iniciativas de organizaciones privadas –aunque algunas con el respaldo indirecto gubernamental). Las filas enumeran algunos organismos e instituciones. Bajo el concepto de promotor se incluyen quién está principalmente detrás de las iniciativas respaldando a las instituciones. Finalmente se presentan algunas normas y marcos de cada ámbito.



Fuente: Telefónica

Figura 1.2. **Actores en el ámbito de la normalización relacionados con las TI**

En el ámbito de la normalización internacional, los organismos de normalización internacionales (ISO, IEC, UIT) y los europeos (CEN, CENELEC, ETSI) disponen de procedimientos estables que garantizan la participación de los países miembros y de la industria local. Aunque cada organismo tiene procedimientos específicos para la realización de la normativa, en todos está garantizada la participación de los países y de sus representantes. Para garantizar la representación se utilizan estructuras de comités, subcomités y grupos de trabajo internacionales, que frecuentemente se reflejan en estructuras similares en los países. Por tanto, no hay un ciclo único para la creación de las normas, aunque todos se basan en la representación de los organismos de normalización de los países a través de sus miembros nacionales (AENOR, BSI, DIN, etc.) como instrumento para garantizar la participación nacional.

Por otra parte, el ámbito de las denominadas iniciativas privadas (ITIL, CMMI, COBIT, etc.) se centra principalmente en el desarrollo de marcos de mejores prácticas y no de normativa. Los procedimientos y la gestión de la representación del sector quedan a la libre elección de la institución u organismo que impulsa la iniciativa (OGC, Carnellie Mellon, ITG, etc.). Con frecuencia se basa en una llamada pública de participación para trabajar en la siguiente edición de estos marcos a la que suelen responder los principales actores internacionales y gurús en la materia. El proceso de selección del equipo de revisión es específico de cada institución, así como el procedimiento de edición de la nueva versión del marco de referencia.

Como se puede intuir hay que ser un autentico especialista en la materia para comprender los diversos esquemas y estructuras que se han ido creando alrededor de la normalización y marcos de mejores prácticas. Por la vinculación con la temática de este libro se explican los procesos de creación de las normas ISO/IEC y de las normas UNE españolas:

Ciclo de creación de las normas ISO/IEC. Una norma internacional se desarrolla en el ámbito de los comités técnicos y de los subcomités técnicos de ISO y de IEC. El proceso sigue seis etapas: propuesta, preparatoria, comité, consulta, aprobación y publicación. En este proceso, el documento propuesta de norma pasa por tres estados que indican el grado de aceptación y apoyo que se va alcanzando de los diversos borradores:

- **CD** (*Committee Draft*): es un borrador generado por un grupo de trabajo, que ha recibido la aprobación del grupo y se remite al comité correspondiente para su aprobación.
- **DIS** (*Draft of International Standard*): es el borrador de norma internacional que el comité de normalización ha aprobado y somete a comentarios y votación por parte de los países.
- **FDIS** (*Final Draft of International Standard*): es el borrador final de la norma internacional, que el comité envía para su aprobación final a todos los miembros para su publicación final como norma internacional.

En la etapa 2, o preparatoria, se emite el borrador de la norma en fase CD. En la etapa 3 se aprueba el borrador para pasar al estado de borrador de comité (DIS) que será sometido a aprobación en la etapa 4 o de consulta. Así, el borrador aprobado pasa al estado de borrador final de norma internacional (FDIS) que será sometido para su aprobación definitiva en la etapa 5.

Además, existe el procedimiento rápido de aprobación, o *fast-track*, para documentos con un grado alto de madurez, como es el caso de normas locales que se quieran elevar a internacionales. En este caso, primero se somete a una votación para

aceptar que la nueva norma se cree por el procedimiento de *fast-track*, para pasar directamente como DIS a la etapa 4. Normalmente el procedimiento rápido puede durar un año, mientras que el normal suele durar entre 2 y 3 años, dependiendo de la dificultad de alcanzar el consenso en las diversas etapas.

Ciclo de creación de las normas UNE españolas. El proceso de elaboración de una norma UNE está sometido a una serie de fases que permiten asegurar que el documento final es fruto del consenso, y que cualquier persona, aunque no pertenezca al comité de AENOR, productor de la norma, pueda emitir sus opiniones o comentarios. Tras la aprobación del proyecto final de norma por un Comité Técnico de Normalización, el Boletín Oficial del Estado (BOE) publica la relación mensual de proyectos UNE sometidos a un período de Información Pública, durante el cual cualquier persona o entidad interesada podrá presentar observaciones. Las observaciones deben realizarse a AENOR. Una vez analizados los comentarios recibidos en esta fase, el comité redactará el texto final, que será aprobado y publicado como norma UNE por AENOR.

En la figura 1.3 se representan las etapas de estos dos ciclos, internacional y nacional.

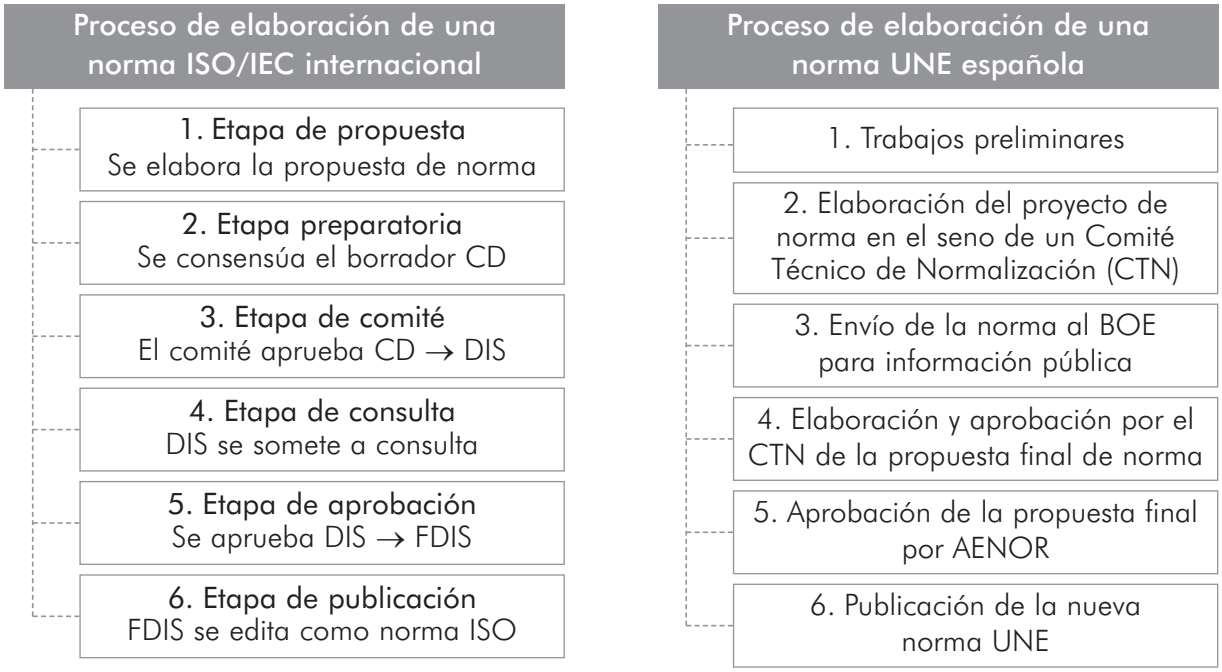


Figura 1.3. **Procedimientos de creación de normas internacionales y nacionales**

A continuación, se presenta una visión general de los principales actores en este ámbito normativo que tienen cierta relevancia en la gestión de las TI, aunque no pretende ser un tratado exhaustivo.

Organismos de normalización internacionales

ISO (*International Organization for Standardization*, Organización Internacional de Normalización). Es el organismo de normalización oficial reconocido a nivel internacional. Su objetivo es poner a disposición de la industria un catálogo de normas sobre productos y servicios que se puedan utilizar para dar garantía de unos niveles de calidad preestablecidos. Fue creado en febrero de 1947 y tiene su sede en Ginebra. Cuenta en la actualidad con la representación de 153 países. Tiene como objetivo lograr la coordinación internacional y la unificación de las normas de la industria. Coopera estrechamente con la IEC.

IEC (*International Electrotechnical Commission*, Comisión Electrotécnica Internacional). Es la organización internacional centrada en la normalización de los ámbitos eléctrico, electrónico y de tecnologías relacionadas. ISO e IEC cooperan estrechamente en campos de interés mutuo, especialmente en el ámbito de las TI en el que desarrollan normas de forma conjunta, las denominadas ISO/IEC.

UIT (*International Telecommunication Union*, Unión Internacional de Telecomunicaciones). Organismo internacional encargado de la elaboración de recomendaciones para el sector de las telecomunicaciones.

Organismos de normalización europeos

CEN (*European Committee for Standardization,* Comité Europeo de Normalización). Es el organismo espejo de ISO a nivel europeo. Está centrado en la normalización en todos los campos excepto en el eléctrico y en el de telecomunicaciones.

CENELEC (*European Committee for Electrotechnical Standardization*, Comité Europeo de Normalización Electrotécnica). Es el organismo espejo de IEC a nivel europeo. Está dedicado a la normalización en el ámbito eléctrico y electrónico.

ETSI (*European Telecommunications Standards Institute*, Instituto Europeo de Normas de Telecomunicación). Organismo equivalente a la UIT para Europa, cuyo campo de actividad se centra en las telecomunicaciones y comunicaciones electrónicas.

Organismos de normalización nacionales

AENOR (Asociación Española de Normalización y Certificación). Es el organismo que desarrolla la actividad de normalización en España. Es una organización privada, independiente y sin ánimo de lucro, reconocida en los ámbitos nacional,

europeo e internacional para el desarrollo de actividades de normalización y certificación (N+C) en un ámbito multisectorial. Cuenta en la actualidad con más de 20 centros operativos repartidos en: España, México, Chile, El Salvador, Italia, Portugal, Brasil, Bulgaria, China, etc. Tiene como objetivo contribuir, mediante el desarrollo de las actividades de N+C, a mejorar la gestión de la calidad en las empresas, sus productos y servicios, proteger el medio ambiente y, con ello, lograr el bienestar de la sociedad en su conjunto.

BSI (*British Standards Institute*). Organismo de normalización del Reino Unido. Es destacable su actividad en la elaboración de nuevas normas en el ámbito de la gestión de las TI. Creador de la serie de normas BS 15000, base sobre la que se han definido las actuales Normas ISO/IEC 20000.

En general, cada país tiene su propio organismo de normalización, entre otros podemos destacar: DIN en Alemania, AFNOR en Francia, UNI en Italia, SA en Australia, etc.

Otros organismos de habla hispana, con los que AENOR mantiene una estrecha colaboración motivada, entre otras cosas, por la traducción conjunta de normas internacionales al español, son: IRAM en Argentina, INN en Chile, DGN en México, INDECOPI en Perú, etc.

Los gobiernos

Es importante destacar el papel activo de los gobiernos, instituciones gubernamentales y administraciones públicas en el campo de la normalización, pues desempeñan un triple papel: como sustento de la actividad de normalización mediante subvenciones a los organismos de normalización, como impulsores de algunas iniciativas destacadas, y en su papel de exigir el cumplimiento de la normativa, bien estableciendo una regulación o bien en su papel de cliente contratante de servicios al sector de las TIC.

Entre estos organismos destacan el Ministerio de Comercio Británico (OGC, *Office of Government Commerce*) en su papel de creador, impulsor y propietario de ITIL y el Departamento de Defensa de Estados Unidos (DoD, *Departament of Defense*) como impulsor de CMMI.

Organismos de acreditación

Las entidades nacionales de acreditación son entidades independientes cuya función es la acreditación de entidades certificadoras y laboratorios de ensayo. Es decir,

el reconocimiento formal de que una organización es competente para la realización de una determinada actividad de evaluación de la conformidad o la realización de un ensayo determinado.

Las organizaciones que podemos destacar son:

- Internacionalmente: IAF (*International Accreditation Forum*).
- En Europa: EA (*European Cooperation for Accreditation*).
- En España: ENAC (Entidad Nacional de Acreditación en España).
- En el Reino Unido: UKAS (*United Kingdom Accreditation System*).

IQNet. Un papel parecido a la acreditación lo realiza la Red Internacional de Certificación (IQNet, *International Certification Network*), asociación formada por las entidades de certificación líderes en la certificación de empresas en sus respectivos países. Entre sus objetivos están:

- El reconocimiento y promoción de los certificados expedidos por sus miembros en todos los sectores industriales y de servicios.
- La coordinación de los procesos de certificación de empresas que operan en distintos países.

Normalmente, los certificados locales emitidos por las entidades certificadoras van acompañados de el reconocimiento internacional de IQNet.

Entidades certificadoras

Para que las empresas puedan demostrar a nivel nacional e internacional que cumplen las normas, necesitan un certificado. Se trata de un instrumento para verificar la correcta implantación de las normas.

La obtención del certificado se realiza mediante un proceso de evaluación independiente por parte de una entidad certificadora o de certificación. Un requisito importante que asegura la solvencia para que una entidad pueda conceder una marca de certificación es que dicha entidad sea "competente para certificar" los productos, los servicios, los sistemas de gestión o las personas, a los que se aplica la marca de certificación.

Los organismos de acreditación son los encargados de acreditar a las entidades de certificación. Las entidades de certificación utilizan los servicios profesionales de los auditores.

Marcas de certificación

Las marcas de certificación las conceden las entidades correspondientes a los productos, sistemas y servicios que cumplen con los requisitos definidos.

La certificación, en base a normas, tiene su reflejo en los distintivos de certificación, cuya concesión significa que el producto o servicio ha pasado por el adecuado proceso de certificación de forma satisfactoria. Cuando, por ejemplo, se trata de una marca de seguridad, la concesión de la marca significará que cumple los requisitos de seguridad, según la norma de referencia.

En un producto con certificado de calidad, la etiqueta puede contener distintos logotipos (véase la figura 1.4) dependiendo de la entidad que otorgue el certificado.



Figura 1.4. **Ejemplos de marcas de certificación de sistema y de producto en el caso de AENOR**

En el Reino Unido se ha desarrollado una marca de certificación específica para ISO/IEC 20000, según un acuerdo interno entre UKAS (organismo de acreditación de ese país) e itSMF-UK (capítulo inglés del itSMF, *Information Technology Service Management Forum*), con un reglamento específico (esquema de certificación). Por el contrario, en la mayoría de los países, la certificación ISO/IEC 20000 transcurre por los caminos habituales de la certificación del país, con marcas específicas de cada entidad certificadora, y regulado por el organismo de acreditación del país.

Auditores

Los auditores son los únicos profesionales acreditados para realizar la auditoría del cumplimiento de los requisitos de una norma por una organización. La calificación de auditor se concede únicamente a los candidatos que demuestren experiencia suficiente y hayan pasado los exámenes exigidos para ello.

En el caso de la Norma ISO/IEC 20000-1, existe una acreditación específica de auditor otorgada por UKAS e itSMF-UK a profesionales con amplia experiencia, tras superar un curso en entidades de formación acreditadas y superar el examen al respecto. Esta acreditación de auditor está vinculada al esquema de certificación conjunto de UKAS e itSMF-UK.

Consultores

Los consultores asesoran, bien a las organizaciones o entidades que quieren implantar las normas, o bien, una vez implantadas, que desean certificarse. Para esta función existe una acreditación profesional específica. La formación que reciben les permite adquirir un nivel suficiente de conocimiento de la normas, del esquema de certificación y de su aplicación.

Los consultores asisten a las organizaciones en la interpretación y aplicación de la normas, así como, para la aplicación efectiva de ISO/IEC 20000 en la gestión del servicio. Asimismo, el consultor externo puede efectuar una evaluación de los niveles de gestión del servicio y establecer el nivel de preparación necesario para una solicitud de certificación y su posterior consecución.

Actualmente, existe una acreditación de consultor ISO/IEC 20000 otorgada por entidades de formación acreditadas por UKAS e itSMF-UK. Otros organismos que regulan la formación profesional (EXIN, APMG) también están entrando en este campo.

Las organizaciones alrededor de ITIL

ITIL (*Information Technology Infrastructure Library*, Biblioteca de Infraestructuras de Tecnologías de la Información) es el compendio de las mejores prácticas en la gestión de TI más extendido y ampliamente aceptado por la industria.

La estrecha relación entre los contenidos de las Normas ISO/IEC 20000 y los libros ITIL, hace relevante conocer cuáles son los principales miembros de este "ecosistema" creado para la difusión y evolución de estas prácticas:

OGC (*Office of Government Commerc*e, Oficina de Comercio del Gobierno). Oficina dependiente del Ministerio de Economía y Hacienda británico, responsable de un amplio programa para mejorar la eficiencia de las empresas. Este organismo (antes denominado CCTA) fue el creador de ITIL a finales de los años 80.

TSO. Editorial inicialmente vinculada al entorno gubernamental británico, centrada en la publicación de libros y documentación producida en este ámbito. Fue privatizada en 1996 y ha sido comprada por el grupo Williams Lea en enero de 2007.

TSO se encarga de la publicación impresa y *online* de los libros ITIL, gestionando sus derechos de propiedad intelectual.

itSMF International (*Information Technology Service Management Forum*, Foro internacional para la Gestión del Servicio de TI). Creado en el Reino Unido en 1991, es una red mundial de grupos de usuarios de TI que ofrecen mejores prácticas y guías basadas en normas para la provisión de servicios de TI. La organización internacional coordina las actividades de los capítulos locales y apoya al desarrollo y difusión de las evoluciones de ITIL.

itSMF está presente en países como: Francia, Bélgica, Alemania, Portugal, Noruega, Japón, Brasil, Dinamarca, Austria, Finlandia, Canadá, EEUU, Singapur, Australia, Italia, Hungría, Rumania, Suecia, Argentina, España, etc.

itSMF España. Capítulo español de itSMF. Constituido como una asociación sin ánimo de lucro, actúa como una comunidad de usuarios. Centra sus intereses en las prácticas y metodologías de gestión y gobierno de las TI. Tiene como objetivo ayudar a las organizaciones a adoptar soluciones de gestión de servicios TI e impulsar la adopción de las mejores prácticas.

Certificación profesional privada en el ámbito de la gestión del servicio

Alrededor de la difusión de las mejores prácticas de gestión del servicio de TI se ha ido creando una oferta de servicios de formación para los profesionales, denominadas "privadas" por no tener asociadas un reconocimiento oficial del Estado, pero muy apreciadas en el mundo empresarial. No se debe confundir esta certificación individual de profesionales con la certificación de organizaciones o proveedores de TI.

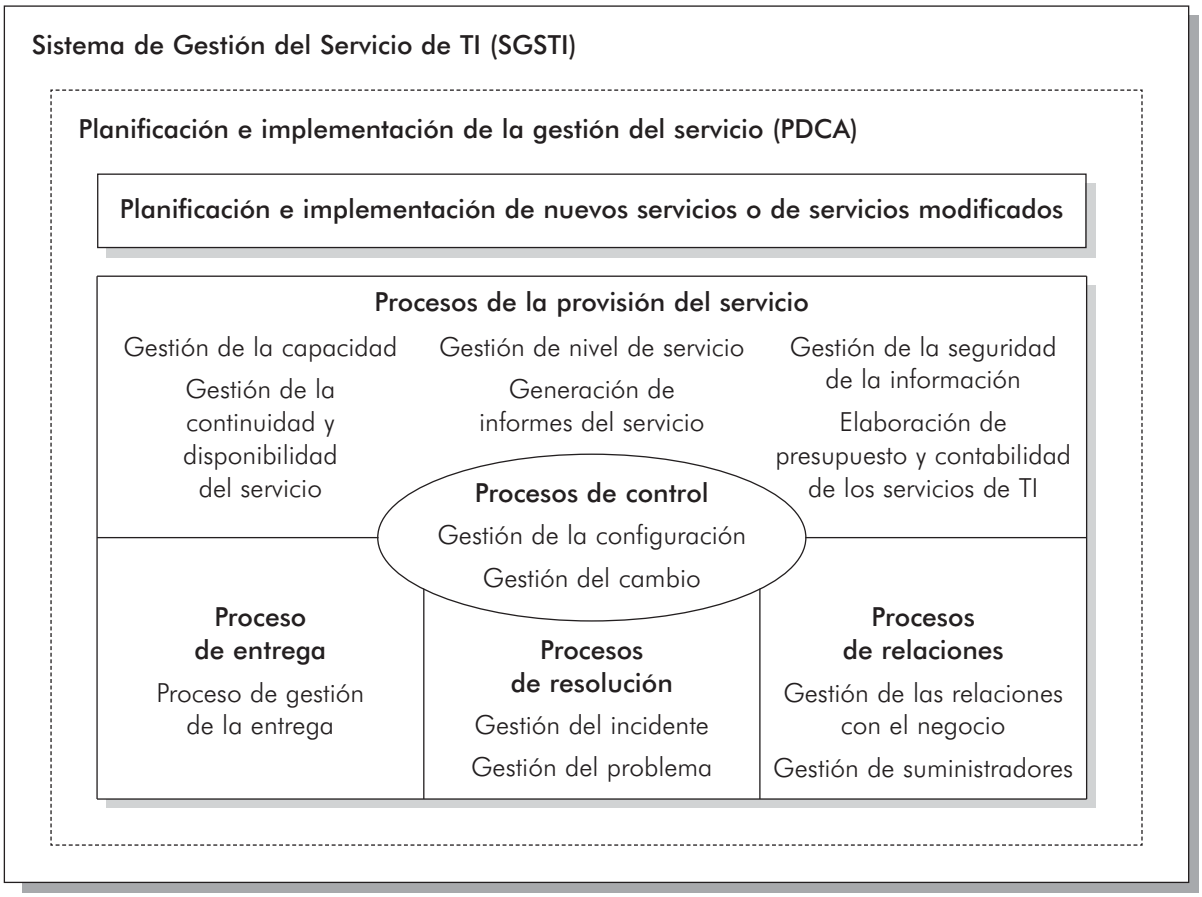
En el ámbito de ITIL, las certificaciones profesionales tienen gran tradición. Se ha evolucionado del esquema anterior de certificaciones de ITIL v2 en tres niveles (*Foundation*, *Clusters* y *Service Manager*) a uno nuevo en ITIL v3 basado en una estructura más flexible de cuatro capas: *Foundation* para los conocimientos generales iniciales, *Intermediate* para el conocimiento en más detalle de uno o varios de los libros del ciclo de vida o de agrupaciones de procesos, *ITIL Expert* que capacita para la gestión integral de los servicios que requiere haber realizado un conjunto de cursos Intermediate e *ITIL Master*, máximo grado de certificación que ratifica la capacidad de analizar y aplicar los conceptos ITIL a nuevas áreas. La calidad de las empresas de formación y el control de los exámenes los gestiona APM Group, a quién la OGC ha otorgado en 2006 la gestión de la acreditación de la formación relacionada con la marca ITIL.

En el ámbito de ISO/IEC 20000, la aparición de estos esquemas de certificación profesional garantizados es más reciente, destaca la iniciativa de EXIN (*Examination Institute for Information Science*), pero posiblemente aparecerán otros, ya que el entorno de normativa internacional no ejerce el concepto de "propietario de marca".

1.4. Las principales normas y buenas prácticas en TI

Las Normas ISO/IEC 20000

Dado que estas normas se tratan en profundidad en el resto del libro, únicamente se presenta en la figura 1.5 un esquema general de su estructuración en 14 procesos (los 13 procesos descritos en los capítulos 6 al 10 de las normas,



Fuente: UNE-ISO/IEC y e.p.

Figura 1.5. **Esquema general de los procesos de ISO/IEC 20000**

junto al proceso del capítulo 5 "Planificación e implementación de nuevos servicios o de servicios modificados"). Además, las normas incluyen dos aspectos muy importantes: el sistema de gestión y la planificación e implementación de la gestión del servicio.

En el ámbito de los servicios de TI, resulta esencial que los servicios se provean en un marco de gestión eficaz y de calidad, para entender claramente los requisitos y gestionar su cumplimiento. Las Normas ISO/IEC 20000 articulan el proceso de prestación de los servicios engranados sobre un sistema de gestión del servicio (véase el capítulo 3). El proceso de mejora continua establecido por la Norma ISO 9001 para la fabricación de productos o prestación de servicios (siguiendo el ciclo PDCA: planificar, hacer, verificar y actuar – *Plan*, *Do*, *Check*, *Act*), también se incorpora en esta norma como un "motor" de la mejora continua de los servicios de TI (véase el capítulo 4).

La serie ISO 9000, normas de calidad

Según el diccionario de la Real Academia Española, la calidad se define como la "propiedad o conjunto de propiedades inherentes a algo que permiten juzgar su valor".

El aseguramiento de la calidad nace como una evolución natural del control de calidad, que resultaba limitado y poco eficaz para prevenir la aparición de defectos. Para ello, se hizo necesario crear sistemas de calidad que incorporasen la prevención como forma de funcionamiento y gestión, y que, en todo caso, sirvieran para anticiparse a los errores antes de que estos se produjeran.

Un sistema de gestión de la calidad se centra en garantizar que el producto o el servicio ofrecido por una organización cumple con las especificaciones establecidas previamente por la empresa y el cliente, y así, asegurar unos niveles de calidad predecibles y su mejora continua a lo largo del tiempo.

El sistema de gestión de la calidad general es el conjunto de elementos interrelacionados de una empresa u organización por los cuales se organiza y planifica el trabajo de la misma en la búsqueda de la satisfacción de sus clientes. Sus elementos principales son:

- La estructura de la organización.
- Sus procesos.
- Sus documentos.
- Sus recursos.

ITIL (*Information Technology Infrastructure Library*)

Es un conjunto de publicaciones que recogen las buenas prácticas en la gestión de servicios de las TI. Define un modelo de procesos bastante amplio que abarca desde la definición de la estrategia hasta la gestión de las infraestructuras. El éxito y la fama de ITIL se han fundamentado en la calidad de sus buenas prácticas y en la flexibilidad para que las empresas pudieran adaptarlas a sus necesidades.

Entre 1989 y 1992, la versión 1 de ITIL se centraba en la gestión de la tecnología y estaba claramente orientado al entorno *mainframe*. Paulatinamente, las prácticas fueron evolucionando hacia procesos y servicios. ITIL, en su versión 2 (de principios del año 2000), se estructuraba en 7 libros básicos (además, hay uno nuevo de dedicado al inventariado o a la gestión de activos *software* y otro enfocado a implementaciones en organizaciones de TI de menor escala como en pymes). En la figura 1.6 se muestra la evolución histórica de ITIL y la aparición de ISO/IEC 20000 en los últimos años.

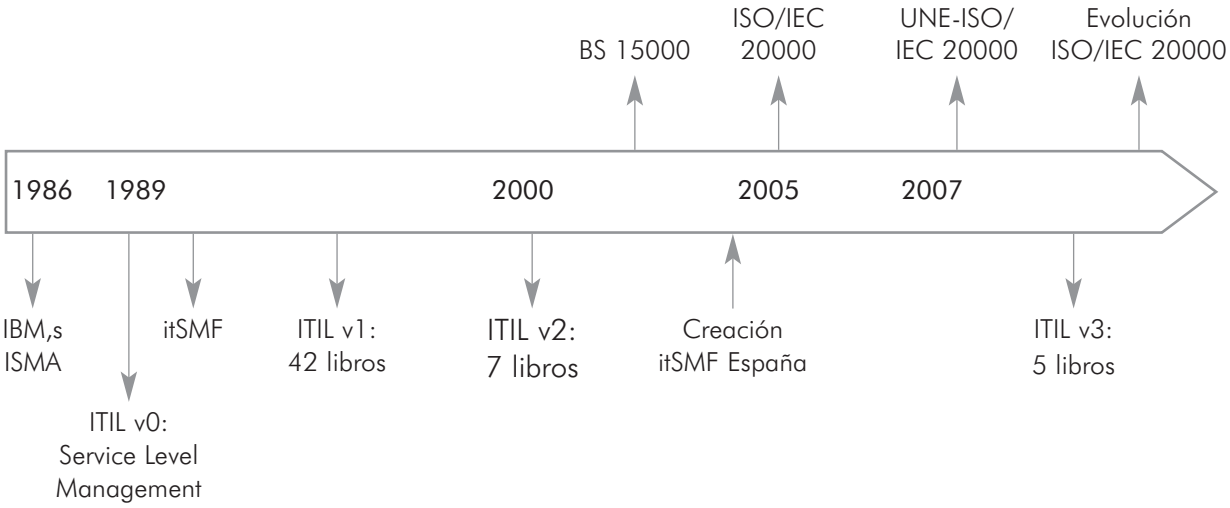
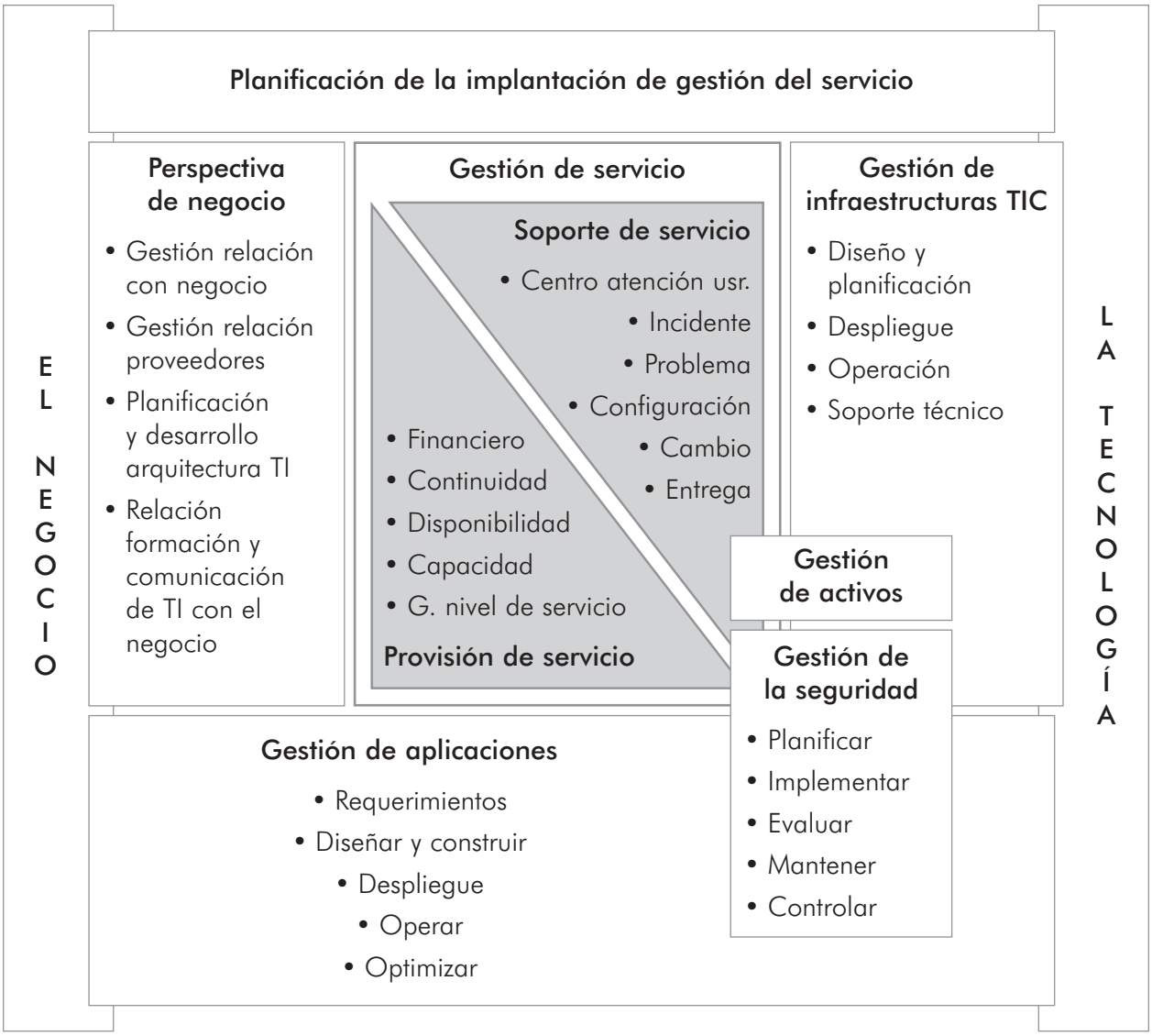


Figura 1.6. **Historia de la evolución de la normativa de gestión del servicio de TI**

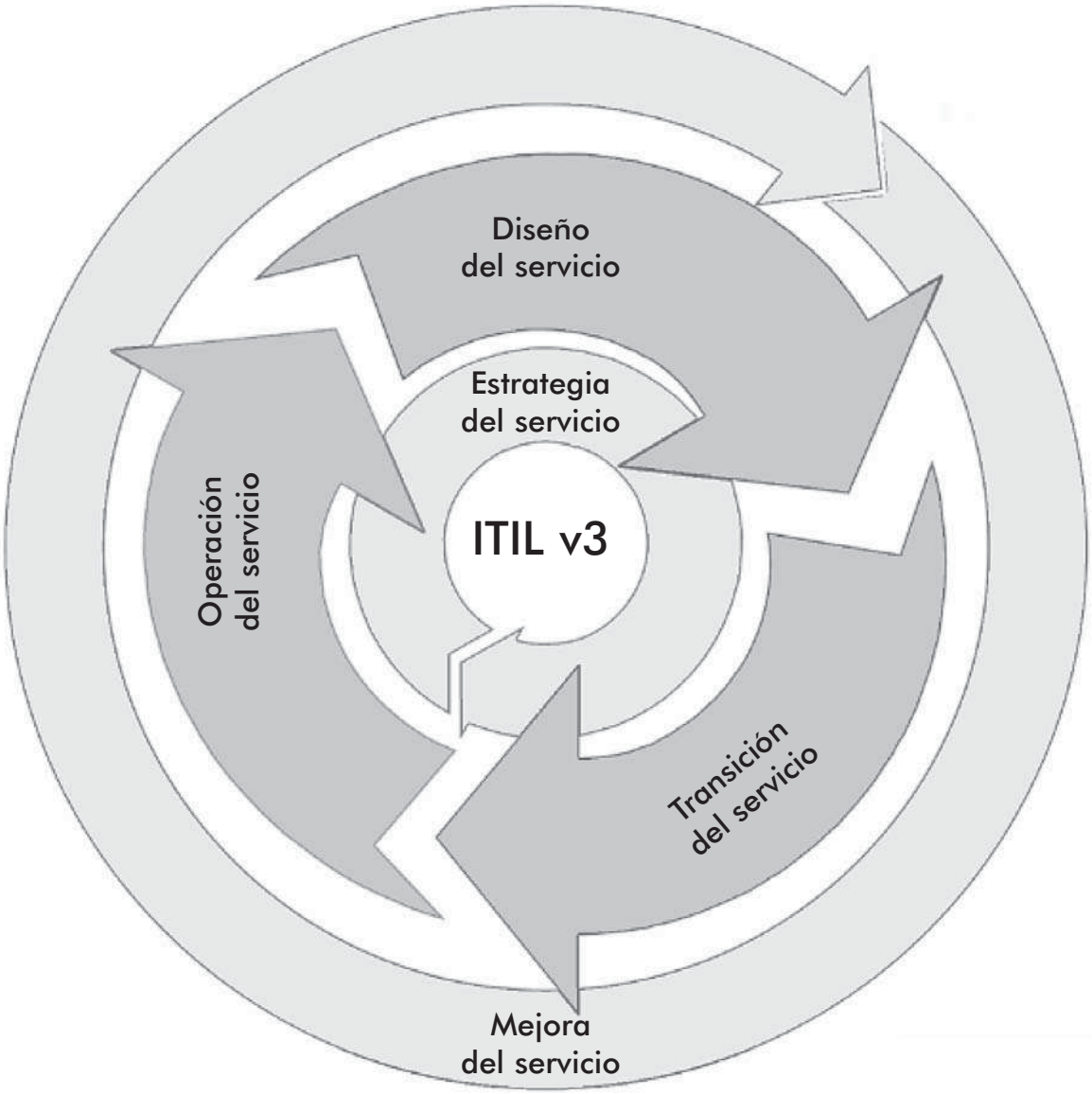
ITIL v2 se ha utilizado como base para la creación de las Normas ISO/IEC 20000. En la figura 1.7, se muestra una representación típica de ITIL v2. En ella se puede apreciar el negocio a la izquierda del todo, en el extremo derecho se sitúa la tecnología, y, en medio, haciendo que la tecnología sea útil para el negocio están los procesos ITIL. De ellos, los dos libros más valiosos por su contenido y más aceptados por el mercado son los relativos a la gestión de servicio (libros *Soporte de Servicio* y *Provisión de Servicio* publicados por OGC).



Fuente: Libro ITIL *Soporte de Servicio* publicado por OGC y e.p.

Figura 1.7. **Procesos definidos en los libros ITIL v2**

La versión 3 de ITIL, que apareció a mediados de 2007, respeta los principales procesos del soporte y de la provisión del servicio ya definidos en la versión anterior. También saca a la luz mucha de las actividades de gestión de TI no reflejadas anteriormente, ampliando su alcance a más de 20 procesos. Esta versión pone mayor énfasis en la integración de TI con el negocio. Se estructura en torno al ciclo completo de creación de servicios: estrategia, diseño, transición, operación y mejora continua (véase la figura 1.8).



Fuente: Libro ITIL *Estrategia del Servicio* publicado por OGC y e.p.

Figura 1.8. **La estructura de los libros ITIL v3 se articula según el ciclo de vida de los servicios**

El conjunto de temática y procesos tratados en ITIL v3 se muestra en la figura 1.9.



Fuente: Libros ITIL v3 publicados por OGC y e.p.

Figura 1.9. **Contenido de las cinco etapas del ciclo de vida de los servicios en ITIL v3**

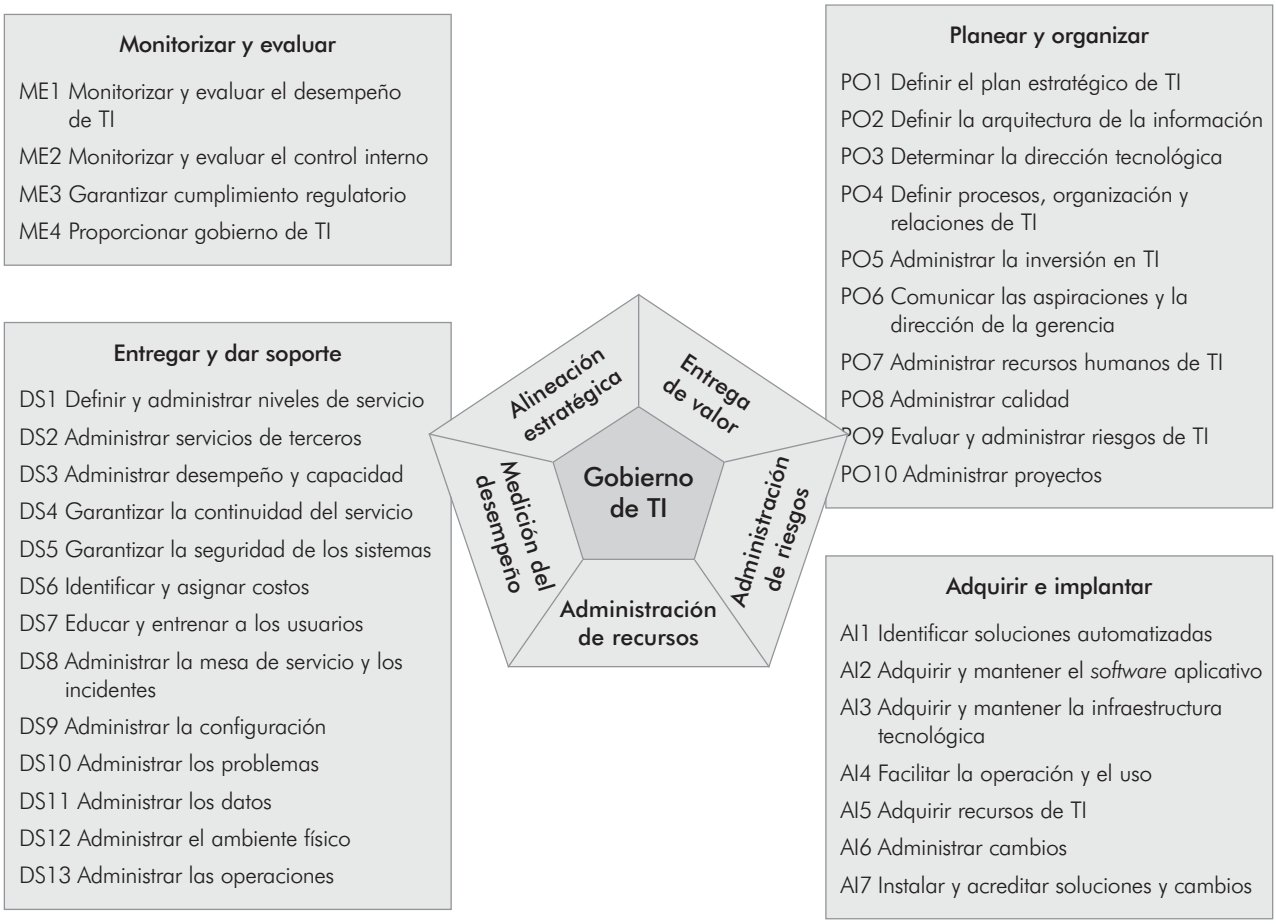
Otras normas y metodologías relacionadas son: COBIT para la auditoría y gobierno de TI, ISO/IEC 27001 para la seguridad, CMMI e ISO/IEC 15504 (SPICE) como modelos de madurez del desarrollo del *software*. En los apartados siguientes se presenta una introducción a ellas.

COBIT (*Control objectives for information and related technology*)

Es un conjunto de mejores prácticas e indicadores para el control y auditoría de los sistemas de información. Fue creado por ISACA (*Information Systems Audit and Control Association*) y el ITGI (IT *Governance Institute*) y ha ido extendiendo su alcance hacia las métricas de TI y las disciplinas de gobierno de las TI.

La primera edición fue publicada en 1996, la segunda en 1998, la tercera en 2000 y la cuarta en Diciembre de 2005.

COBIT 4 se estructura en cuatro dominios que cubren un total de 34 objetivos principales de control (denominados también procesos), que permiten garantizar un adecuado sistema de gobierno para el entorno de las TI. En la figura 1.10 se muestran estos dominios.



Fuente: ISACA.

Figura 1.10. **Los 4 dominios de COBIT para el gobierno de TI**

En el ámbito de la certificación de los profesionales, en 2008 ISACA ha puesto en marcha la certificación en el gobierno de las TI (CGEIT, *Certified in the Governance of Enterprise IT*). Además, existe la acreditación a título profesional para auditor de las TI (CISA, *Certified Information Systems Auditor*) y la relativa a la seguridad de las TI (CISM, *Certified Information Security Manager*).

Vinculado a COBIT, y con el fin de desarrollar las prácticas para la medición de del valor de la contribución de TI al negocio, ISACA ha creado el marco Val IT.

ISO/IEC 27001 e ISO/IEC 17799 para la seguridad de las TI

El objetivo de la gestión de la seguridad de la información es asegurar la continuidad de las operaciones de la organización y reducir al mínimo los daños causados por una contingencia, así como, optimizar la inversión en tecnologías de seguridad.

ISO/IEC 27001 establece los principios de: integridad, disponibilidad y continuidad de la información. Proporciona un modelo para la creación, implementación, operación, supervisión, revisión, mantenimiento y mejora de un sistema de gestión de la seguridad de la información (SGSI). Esta norma establece un conjunto de 30 actividades para la gestión de la seguridad, define 11 áreas principales de control, para cada una establece 39 objetivos de control y 133 controles (o medidas de salvaguarda) de seguridad. Las áreas de control son:

- Área: 5. Política de seguridad.
- Área: 6. Aspectos organizativos de la seguridad de la información.
- Área: 7. Gestión de activos.
- Área: 8. Seguridad ligada a los recursos humanos.
- Área: 9. Seguridad física y ambiental.
- Área: 10. Gestión de comunicaciones y operaciones.
- Área: 11. Control de acceso.
- Área: 12. Adquisición, desarrollo y mantenimiento de los sistemas de información.
- Área: 13. Gestión de incidentes de seguridad de la información.
- Área: 14. Gestión de la continuidad del negocio.
- Área: 15. Cumplimiento.

En la figura 1.11 se muestra la estructura de actividades propuesta en la norma.

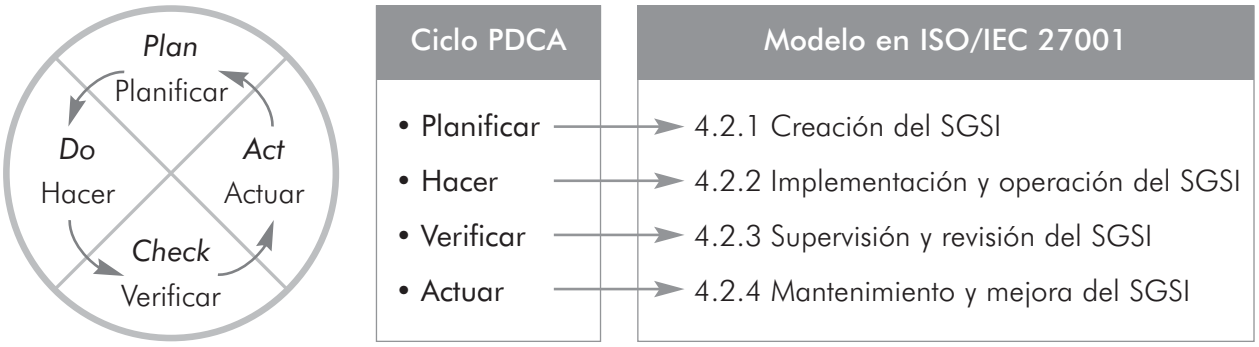


Figura 1.11. **Estructura de actividades de ISO/IEC 27001**

ISO/IEC 17799 (que pasará a ser denominada ISO/IEC 27002) recoge un código de buenas prácticas para la gestión de la seguridad de la información. Se centra en desarrollar los objetivos de control de la seguridad, y para cada uno de ellos, se indica una guía para su implantación. Cada organización debe considerar cuántos serán realmente los aplicables según sus propias necesidades.

CMMI (*Capability Maturity Model Integration*)

CMMI es una evolución de estándar inicial CMM, que fue desarrollado por el SEI (Software Engineering Institute) de la universidad Carnegie Mellon, en 1986. Fue iniciado en respuesta a la petición del Gobierno de los EEUU (Departamento de Defensa, DoD) de proporcionar un método para controlar la capacidad de desarrollo de *software* de sus contratistas.

Originalmente, fue diseñado para su uso por los desarrolladores de *software*, pero hoy se ha ampliado, proporcionando un modelo completo de evaluación de la madurez de las actividades de desarrollo de aplicaciones de una organización. Este modelo está estructurado y repleto de prácticas de gran utilidad para la mejora de las actividades de una organización de TI.

En la figura 1.12 se muestra la estructura de las prácticas de CMMI en cuatro áreas denominadas constelaciones. Cada una de estas constelaciones se pueden considerar equivalentes a un libro de ITIL. En el modelo CMMI a los procesos se les denomina área de proceso (PA, *Process Area*). Se establece una constelación común (CMMI Fountation) que contiene los procesos que son comunes, una específica

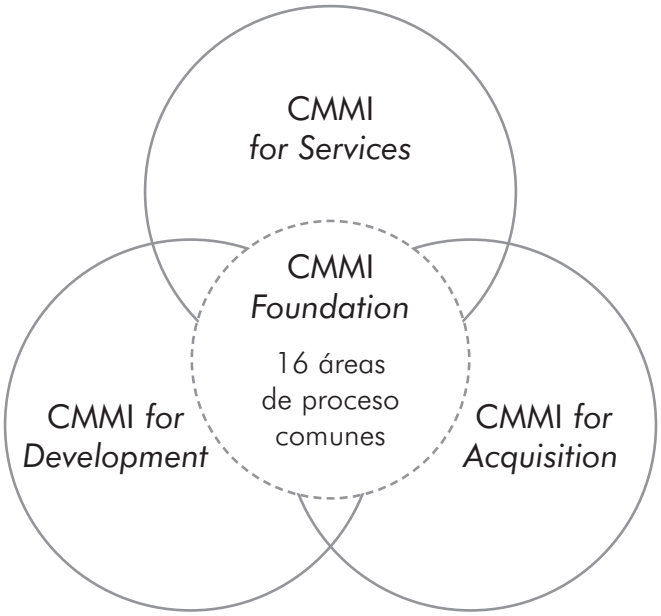


Figura 1.12. **Constelaciones (áreas o libros) de CMMI**

para el desarrollo de aplicaciones (CMMI *for Development*), otra para las adquisiciones (CMMI *for Adquisition*) y una nueva para la prestación de servicios (CMMI *for Services*).

CMMI describe cinco etapas evolutivas (niveles) en las cuales una organización se sitúa según la madurez de sus procesos:

1. **Inicial** (*Initial)*. Los procesos son caóticos; pocos procesos están realmente definidos.
2. **Repetible** (*Repeatable*). Se establecen los procesos básicos y se observa cierto nivel de disciplina respecto a ellos.
3. **Definido** (*Defined*). Todos los procesos están definidos, documentados, normalizados e integrados.
4. **Gestionado** (*Managed*). Los procesos se miden recogiendo datos detallados de los mismos.
5. **En optimización** (*Optimizing*). La mejora de los procesos es continua y proporciona nuevas ideas y oportunidades.

Con la publicación en Marzo del 2009 de CMMI *for Services*, el SEI también entra en el ámbito de la gestión del servicio, con bastante solape con ITIL e ISO/IEC 20000. En la figura 1.13 se muestran los procesos de este nuevo modelo.

Las 24 áreas de proceso (PA) en CMMI-SVC

Support

- *Causal Analysis and Resolution* (CAR)
- *Configuration Management* (CM)
- *Decision Analysis and Resolution* (DAR)
- *Measurement and Analysis* (MA)
- *Process and Product Quality Assurance* (PPQA)

Service Establishment and Delivery

- *Incident Resolution and Prevention* (IRP)
- *Service Delivery* (SD)
- *Service System Development* (SSD)
- *Service System Transition* (ST)
- *Strategic Service Management* (STSM)

Process Management

- *Organizational Innovation and Deployment* (OID)
- *Organizational Process Definition* (OPD)
- *Organizational Process Focus* (OPF)
- *Organizational Process Performance* (OPP)
- *Organizational Training* (OT)

Project Management

- *Capacity and Availability Management* (CAM)
- *Integrated Project Management* (IPM)
- *Project Monitoring and Control* (PMC)
- *Project Planning* (PP)
- *Requirements Management* (REQM)
- *Risk Management* (RSKM)
- *Quantitative Project Management* (QPM)
- *Service Continuity* (SCON)
- *Supplier Agreement Management* (SAM)

Fuente: SEI.

Figura 1.13. **Los procesos definidos en CMMI para servicios (CMMI-SVC) en su versión 1.2**

ISO/IEC 15504 (SPICE, *Software Process Improvement and Capability dEtermination*)

En el ámbito del desarrollo del *software* en enero de 1993 en el seno del comité conjunto de ISO e IEC, surge el proyecto SPICE para el desarrollo de un estándar internacional para la evaluación de los procesos de construcción del *software*. El resultado de este trabajo se plasmó en la serie de normas ISO/IEC 15504, que presentan un modelo de referencia que describe los procesos de una organización para ejecutar, adquirir, desarrollar, operar, evolucionar y proporcionar soporte al *software*. Este marco es la respuesta de la normativa internacional al modelo de madurez CMMI *for Development* y en muchos aspectos se solapa.

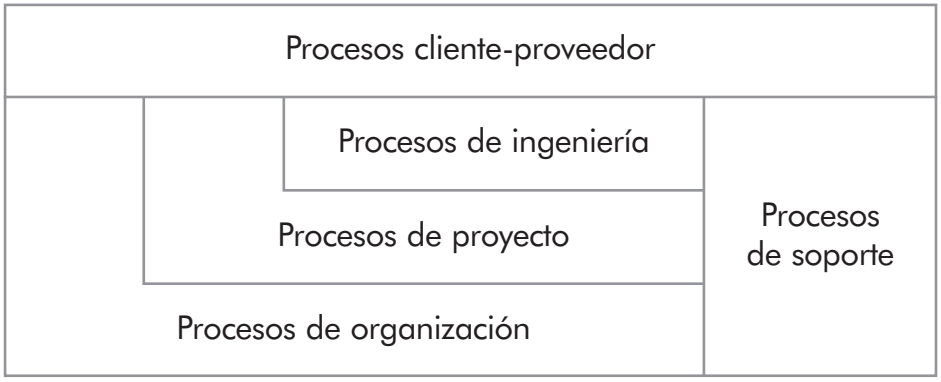
La arquitectura del modelo organiza las prácticas en números de categorías utilizando diferentes tipos de aproximaciones. La arquitectura distingue entre:

- **Prácticas base**. Actividades esenciales de un proceso específico, agrupado por categorías de procedimientos y procesos de acuerdo al tipo de actividad.
- **Prácticas genéricas**. Aplicables a cualquier proceso, que representa las actividades necesarias para administrar el "proceso" y mejorar su potencialidad.

El modelo agrupa a los procesos en cinco categorías:

- **Procesos cliente-proveedor** (*customer-supplier*). Esta categoría consta de los procesos que directamente impactan al cliente, al soporte de desarrollo y a la transición del *software* al cliente.
- **Procesos de ingeniería** (*engineering*). Esta categoría consta de los procesos que directamente especifican, implementan, y mantienen un sistema, un producto de *software* y la documentación del usuario.
- **Procesos de proyecto** (*project*). Esta categoría consta de los procesos establecidos dentro del proyecto, coordinación y administración de los recursos para producir un producto o proveer un servicio para satisfacer al cliente.
- **Procesos de soporte** (*support*). Esta categoría consta de los procedimientos que establecen y soportan el desempeño de los otros procesos del proyecto.
- **Procesos de la organización** (*organization*). Esta categoría consta de los procesos que establecen las metas de negocio de la organización, los procesos de desarrollo y los recursos que ayudan a la organización alcanzar dichas metas.

En la figura 1.14 siguiente se muestra un esquema con estos procesos:



Fuente: SPICE.

Figura 1.14. **Las cinco categorías de procesos definidas en SPICE**

Existen seis niveles de capacidad en el modelo:

- **Nivel 0: Incompleto**. Sería un fracaso general tratar de aplicar las prácticas base a los procesos, ya que no es fácil identificar las salidas de los procesos o el funcionamiento de los productos.
- **Nivel 1: Realizado**. Generalmente se ejecutan las prácticas base de los procesos. La ejecución de dichas prácticas puede no ser planificada rigurosamente y ni seguida, y dependerá del conocimiento y esfuerzo personal. Se identifican algunos procesos.
- **Nivel 2: Gestionado**. Se planifica y se sigue la ejecución de las prácticas base en los procesos. El desempeño estará acorde con los procedimientos especificados. La primera distinción entre el nivel 1 y el 2 es que la ejecución de los procesos está planificada y administrada y progresan hacia un modelo bien definido.
- **Nivel 3: Establecido**. Las prácticas bases se ejecutan de acuerdo a una versión adaptada del estándar. Los procesos están aprobados, bien definidos y documentados.
- **Nivel 4: Predecible**. Se recaban y evalúan las mediciones detalladas del rendimiento o ejecución. Se conoce de forma cuantitativa el rendimiento de los procesos y es posible su predicción. Las prácticas se administran objetivamente. La calidad de las mismas se conoce cuantitativamente.
- **Nivel 5: Optimizado.** Se establecen en forma cuantitativa procesos y metas eficientes, basados en los objetivos de la organización. Los procesos se van mejorando de forma continua, mediante la retroalimentación (*feedback*) obtenida por los resultados de procesos definidos, por ideas, por pilotos y por nuevas tecnologías.

Capítulo 2

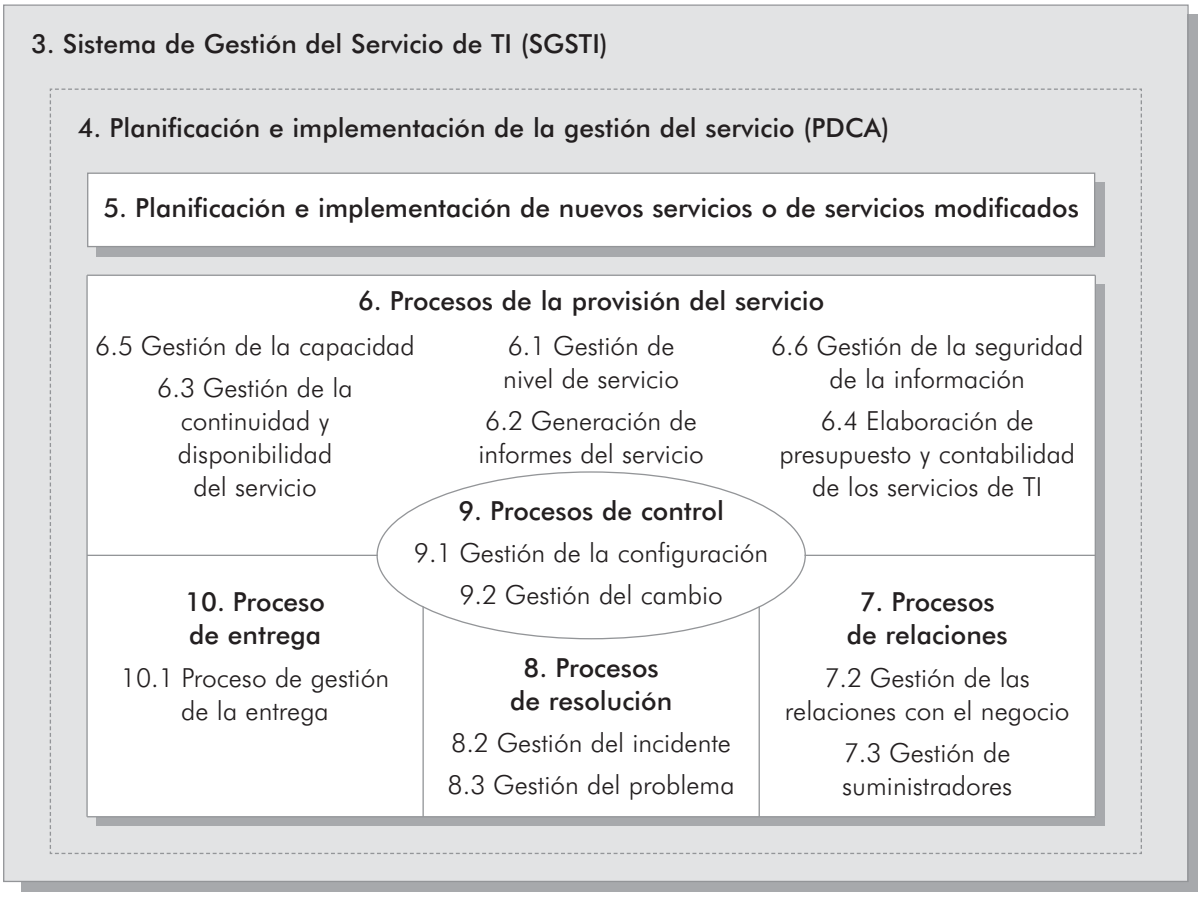
2 Entender las Normas ISO/IEC 20000

2.1. Introducción a las Normas ISO/IEC 20000

2.2. Objeto y campo de aplicación de ISO/IEC 20000

2.3. La estructura de las Normas ISO/IEC 20000

2.4. Relación entre ISO/IEC 20000 e ITIL



Fuente: UNE-ISO/IEC y e.p.



2.1. Introducción a las Normas ISO/IEC 20000

La serie de Normas ISO/IEC 20000 (UNE-ISO/IEC 20000 en la versión española) es el primer conjunto de normativa internacional específica para la gestión de los servicios basados en las Tecnologías de la Información (TI). Presentan una organización cabal de las principales actividades necesarias para gestionar estos servicios, agrupadas en un conjunto de procesos considerados esenciales para la creación, prestación y evolución de los servicios de las TI. Al aplicar sus requisitos y recomendaciones, las organizaciones de TI emprenderán un camino indudable de mejora en el control y la calidad de su actividad. Es el primer gran salto hacia la excelencia demandada por la sociedad a las TI.

Se pueden considerar como normas "troncales" en la gestión de las TI, pues estructuran en torno a procesos las actividades más esenciales. Alrededor del eje vertebrador que crean las Normas ISO/IEC 20000 se irán construyendo y transformando el resto de las funciones de la organización de las TI. Sobre este núcleo central, creado para la gestión de las TI, se irán incorporando otras mejores formas de hacer proporcionadas por otras normas, otros marcos de mejores prácticas, por la experiencia propia de la empresa o por las aportaciones de consultores externos.

Las Normas ISO/IEC 20000 introducen en la organización de las TI una forma de trabajo metódica, integrada y orientada a los procesos, haciendo especial énfasis en garantizar la calidad del servicio a los distintos clientes de las TI. Además, articulan su implantación con un sistema de gestión específico, que incorpora la disciplina y el rigor de ISO 90000 en la implantación del modelo de trabajo en las TI.

Las Normas ISO/IEC 20000 forman parte del conjunto de normas producidas por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC). Su adopción como normas internacionales surge a raíz de la iniciativa de elevar a ISO e IEC las normas británicas BS 15000 relativas a la gestión del servicio de las TI. Las Normas ISO/IEC 20000 hoy vigentes se tramitaron en ISO a través del procedimiento rápido denominado procedimiento *fast-track*. Esto quiere decir, que estas normas tienen muchas similitudes con la original, que la duración del proceso es de aproximadamente un año, y que ha contado con la participación y voto de los representantes nacionales en ISO/IEC.

Las Normas ISO/IEC 20000 se componen de dos partes: la primera es la especificación para la gestión del servicio y tiene un carácter preceptivo, y la segunda se establece como un código de buenas prácticas o recomendaciones. Ambas partes forman un marco para definir las características de los procesos implicados en la gestión del servicio, que son esenciales para la prestación de los mismos con la calidad requerida.